

Attacchi alle Reti parte 2

Cosa Vuol dire Null Session:

Null Session sta per (Sessione Nulla) è una connessione anonima a un sistema di rete che avviene senza fornire un nome utente o una password.

Il protocollo SMB e il servizio NetBIOS utilizzano una condivisione nascosta speciale chiamata IPC\$(Inter Process Communication).

- Il client richiede l'accesso a IPC\$ lasciando i campi delle credenziali vuoti.
- Il server accetta la richiesta e apre un canale di comunicazione
- Attraverso questo canale, l'utente anonimo può interrogare le API del sistema operativo

Un hacker può avviare una sessione nulla da un terminale e avviare una pericolosa fase di enumerazione(Raccolta informazioni) un malintenzionato che si collega in questo modo può estrarre:

- Nomi degli account utente o gruppi presenti nel sistema
- Risorse e cartelle condivise
- Chiavi del registro di sistema remoto.

“FUNZIONA SU UNA STESSA LAN QUINDI IN UNA STESSA RETE, FUNZIONA ANCHE SU INTERNET QUANDO SI PARLA DI SERVER CLOUD ESPOSTI”

Sistemi che sono vulnerabili a Null Session e sono in commercio:

Vecchi sistemi Windows xp, Windows Server 2003 e sistemi vulnerabili a causa di compatibilità, configurazioni errate come Dispositivi NAS economici, sistemi IoT ecc...

Mitigazione per la risoluzione di attacchi NULL Session:

- Disabilitare protocolli Obsoleti come SMBv1 e forzare l'utilizzo di SMBv2 o ancora meglio SMBv3
- Mitigare a livello firewall attivando solo le porte SMB per indirizzi ip fidati e autorizzati
- Bloccare il traffico non autorizzato sulle porte TCP445(SMB over TCP) TCP 139, UDP 137, 138.

Cos'è L'ARP Poisoning:

È una tecnica di attacco in cui un malintenzionato invia messaggi ARP falsificati(ARP request) all'interno di una rete locale(LAN), l'obiettivo è associare l'indirizzo MAC dell'attaccante con l'indirizzo IP di un altro dispositivo(host) legittimo. Una volta riuscito l'attaccante potrà sniffare il traffico dato che esso passerà attraverso il suo dispositivo prima di raggiungere internet, permettendogli di spiare, intercettare e modificare i dati (ATTACCO MAN-IN-THE-MIDDLE).

Su Quali Sistemi Funziona?

L'ARP poisoning sfrutta una debolezza del protocollo IPv4, di conseguenza funziona su tutti i sistemi operativi:

- Windows, MacOS, Linux, IOS, Android sono tutti vulnerabili se la rete LAN non è protetta
- Funziona su qualsiasi dispositivo di rete come stampanti di rete, telecamere IP, smart tv ecc...
- È un attacco puramente LAN: come le Null session, richiede che l'attaccante sia fisicamente o virtualmente all'interno della stessa rete locale.

Mitigazione ARP poisoning e come rilevarlo

Controllare attraverso il prompt o la bash la tabella cache ARP locale del tuo computer e vedere le varie corrispondenze, se si nota che l'indirizzo MAC del router è identico a quello di un altro dispositivo nella cache ARP allora significa che il traffico è stato intercettato. Si può anche utilizzare wireshark per visualizzare attraverso la cattura dei pacchetti "Duplicate IP address configured" o "ARP spoofing"

Per risolvere il problema possiamo obbligare a fissare l'indirizzo MAC del router ed ignorare le richieste false dell'attaccante.

Oppure via hardware tramite:

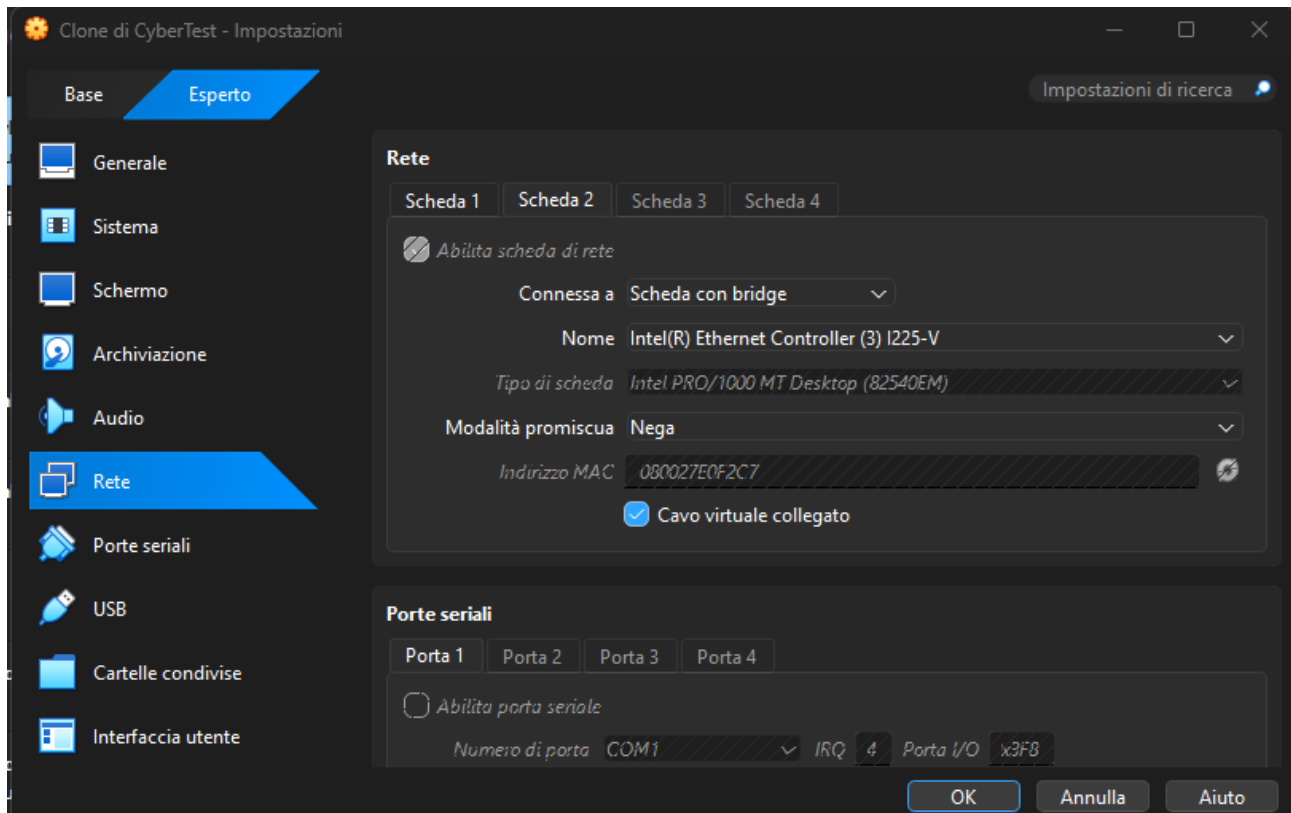
- DHCP Snooping: lo switch controlla tutti i messaggi DHCP della rete e crea una tabella sicura.
- DAI(Dynamic ARP Inspection): Una volta attiva la tabella precedente, lo switch intercetta ogni singolo pacchetto ARP che passa tra i cavi. Se l'associazione IP/MAC contenuta nel pacchetto ARP non corrisponde a quella della tabella sicura, lo switch taglia la connessione di quella porta e isola l'attaccante.

Tramite cifratura:

- Cifratura tramite utilizzo di VPN e forzatura di connessioni cifrate come HTTPS

Esercizio su Ettercap:

Proviamo ad eseguire un ARP poisoning utilizzando come tool Ettercap uno strumento presente su kali linux per attuare vari attacchi LAN. Per fare ciò configuriamo entrambe le VM Kali(L'attaccante) e metasploit(La vittima) in modalità bridged quindi in comunicazione diretta con il router.



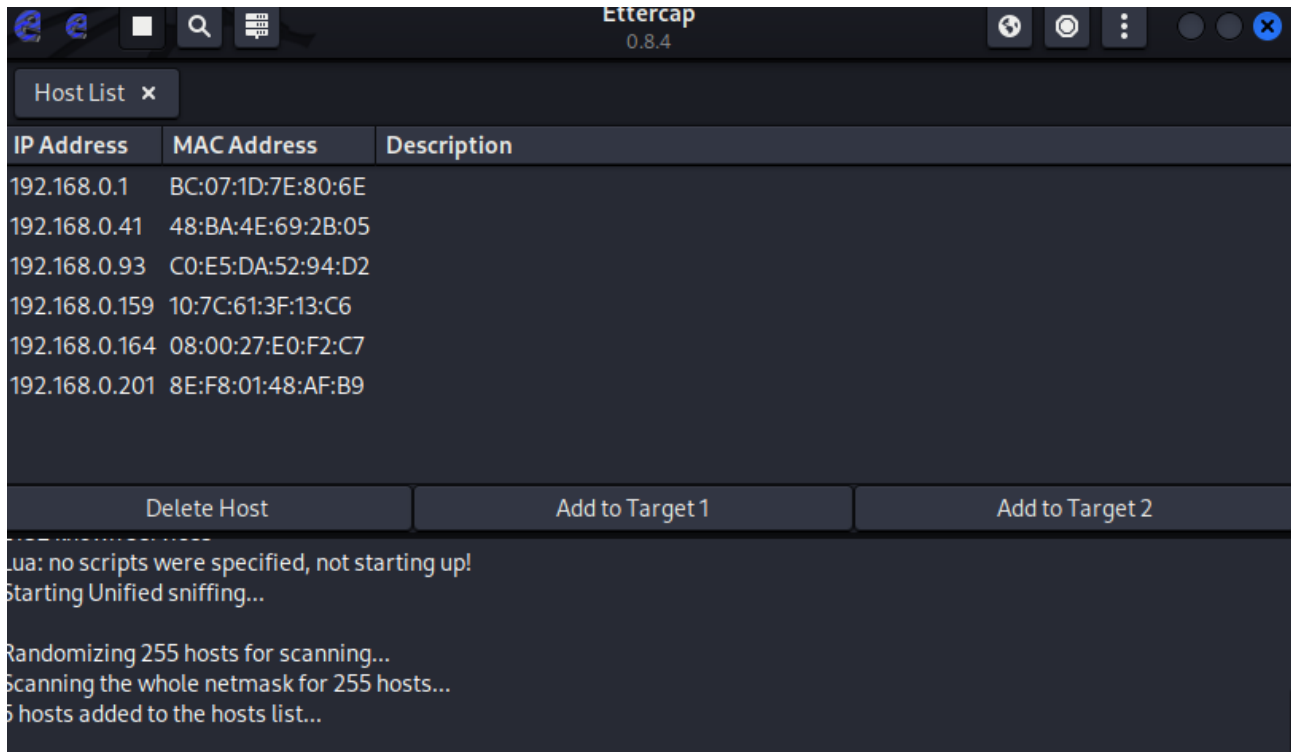
Successivamente andiamo a configurare nella metasploit il gateway per comunicare tramite il router di casa in maniera automatica tramite dhcd scrivendo **“sudo dhclient eth1”**:

```
Listening on LPF/eth1/08:00:27:e0:f2:c7
Sending on   LPF/eth1/08:00:27:e0:f2:c7
Sending on   Socket/fallback
DHCPDISCOVER on eth1 to 255.255.255.255 port 67 interval 8
DHCPOFFER of 192.168.0.164 from 192.168.0.1
DHCPREQUEST of 192.168.0.164 on eth1 to 255.255.255.255 port 67
DHCPACK of 192.168.0.164 from 192.168.0.1
bound to 192.168.0.164 -- renewal in 3465 seconds.
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:02:5b:ea brd ff:ff:ff:ff:ff:ff
    inet 192.168.50.101/24 brd 192.168.50.255 scope global eth0
    inet6 fe80::a00:27ff:fe02:5bea/64 scope link
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:e0:f2:c7 brd ff:ff:ff:ff:ff:ff
    inet 192.168.0.164/24 brd 192.168.0.255 scope global eth1
    inet6 fe80::a00:27ff:fee0:f2c7/64 scope link
        valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$
```

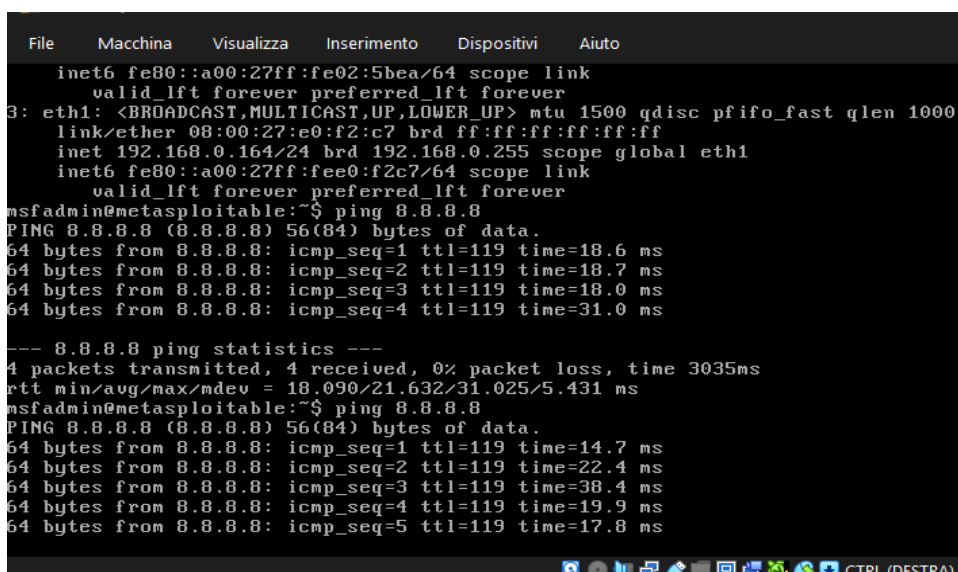
In questo modo come possiamo vedere verrà assegnato un indirizzo IP casuale dal router stesso.

Adesso dalla kali(Già precedentemente configurata in bridged) attiviamo ettercap ed eseguiamo una scansione della rete bridged per rilevare la nostra vittima(metasploit) ed attuare successivamente un ARP poisoning:

Effettuiamo la scansione su Ettercap attraverso i tre puntini>hosts>scan for all hosts>



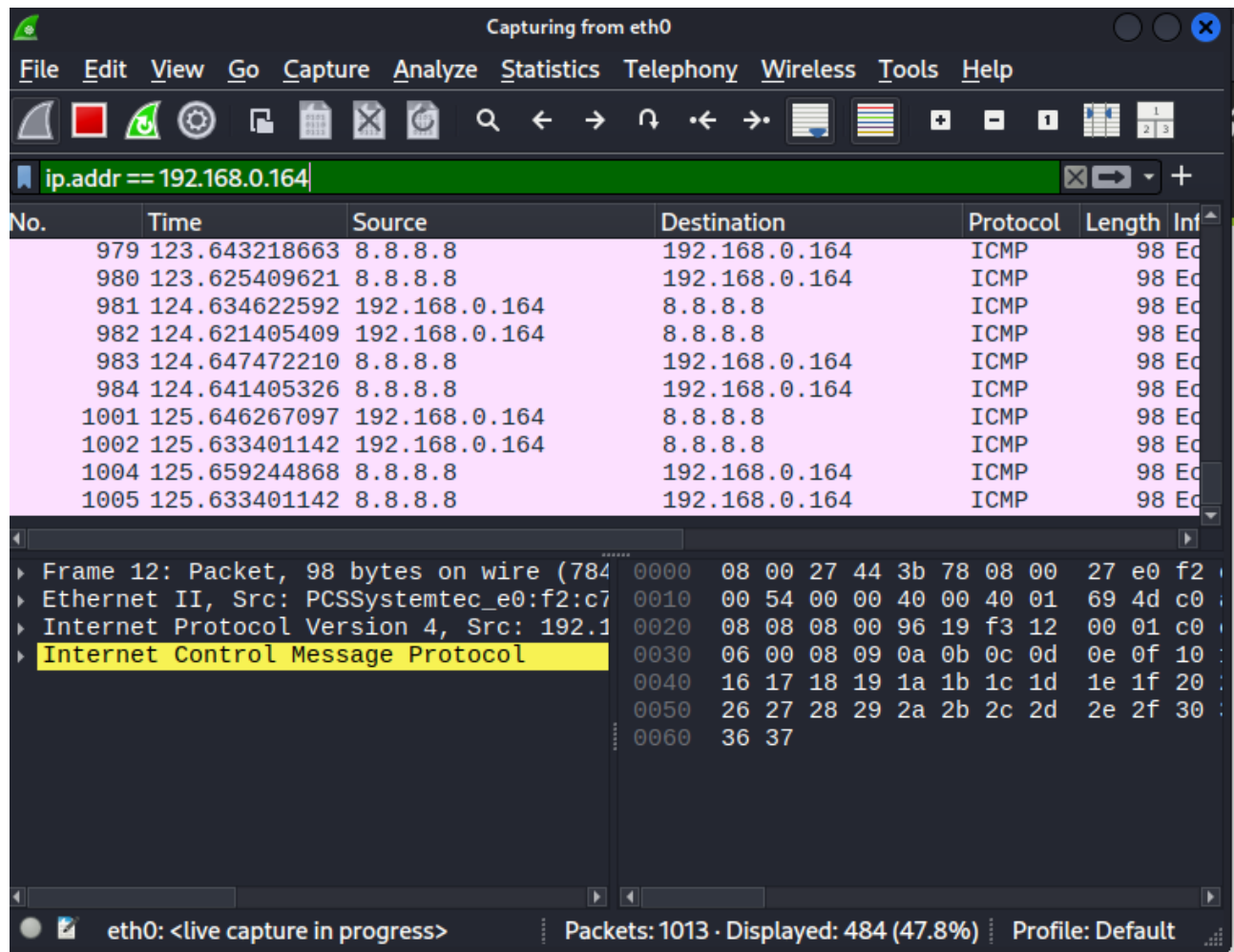
Come possiamo vedere è stato rilevato l'indirizzo ip vittima(192.168.0.164) adesso per effettuare l'ARP poisoning e sniffare i pacchetti tramite wireshark facciamo "add to target



1" il gateway del router ovvero "192.168.0.1" e come secondo target l'indirizzo della vittima, in questo modo ettercap invierà delle richieste ARP false per prendere il posto del gateway ed intercettare tutto il traffico prima che

venga mandato in rete e successivamente lo inoltra al vero gateway senza alterarlo per rendere l'intercettazione invisibile.

Dopo aver avviato l'attacco ARP poisoning da ettercap effettuiamo un **"ping 8.8.8.8"** dalla metasploit e tramite wireshark andiamo a sniffare il traffico per vedere cosa succede:



Come possiamo vedere l'attacco è stato un successo e riusciamo ad intercettare e sniffare tramite **Wireshark** i pacchetti **dell'host** vittima che ci crede il **gateway**.

